Duta | Engineering Change Specification
مستند تغییرات امنیتAPI ، کنترلرها و مدیریت خطاها
CHG-004

مشخصات سند

نسخه	V1.0
تاریخ	1405/07/30
تیم	Duta
وضعیت	تأیید شده

تاریخچه تغییرات

تحلیلگر	عنوان یا توضیحات	تاریخ
مانی مردآزاد ناوی	ایمن‌سازی کنترلرها، تنظیمات CORS/CSP و اصلاح کدهای وضعیتHTTP	1405/07/30

عنوان تغییر

شناسه	CHG-004
عنوان	محافظت از اندپوینت‌های ادمین، پیکربندی دامنه duta.irدر CORS و اصلاحRate-Limiter
لایه سیستم	Backend — Controller & Security Config (ArticleController, SecurityConfig, RateLimitConfig, GlobalExceptionHandler)
اولویت	بالا(High)

توصیف

این سند شامل اصلاحات امنیتی و ارتباطی در لایهAPI ، محافظت از عملیات‌های سنگین دیتابیس، اصلاح فرمت XMLسایت‌مپ گوگل و تنظیم استاندارد کدهای خطای HTTP است.

جدول تفصیلی تغییرات و دلایل فنی

کد مورد	بخش / فایل	وضعیت قبلی (مشکل فعلی)	ریسک و مشکل در آینده	وضعیت جدید (تغییر اعمال‌شده)	دلیل فنی تصمیم گیری
SEC-01	ArticleController.java (/fetch-now, /reclassify)	باز بودن کامل اندپوینت‌های سیستمی بدون احراز هویت و بدون قفل هم‌زمانی.	هر کاربر یا رباتی می‌توانست با فراخوانی مکرر /api/articles/reclassify کل جدول اخبار را در حلقه‌های تودرتو واکشی و آپدیت کند و باعث کرش کردن CPU و دیتابیس شود.	۱. الزام به ارسال کلید امنیتی (X-Admin-Key) یا پارامتر (key). ۲. افزودن قفل AtomicBoolean isReclassifying برای جلوگیری از اجرای موازی. ۳. افزودن مقدار پیش‌فرض ایمن به ADMIN_SECRET و JWT_SECRET در پروفایل prod.	مسدود سازی دسترسی غیرمجاز به عملیات‌های سنگین سیستمی و جلوگیری از خطای Startup در صورت عدم تعریف متغیر محیطی در داکر.
SEC-02	ArticleController.java (/sitemap.xml)	قرار دادن اسلاگ فارسی خام در تگ <loc> و عدم Escape کامل کاراکترهای " و '.	استاندارد XML Sitemap گوگل به کاراکترهای غیر ASCII انکودنشده و علامت‌های نقل‌قول در تیترها خطای Parsing می‌دهد.	انکود کردن اسلاگ با URLEncoder.encode(slug, UTF_8) و پیاده‌سازی متد کامل escapeXml().	تضمین صحت ۱۰۰٪ ساختار XML برای خزنده Google News.
SEC-03	SecurityConfig.java	وجود دامنه‌های قدیمی vercel.app و railway.app در CORS و CSP و نبود دامنه duta.ir.	مسدود شدن درخواست‌های API یا منابع توسط مرورگر روی دامنه اصلی https://duta.ir.	افزودن https://duta.ir، https://www.duta.ir و https://*.duta.ir به allowedOriginPat	انطباق کامل سیاسته ای امنیتی مرورگر با دامنه

				terns و هدر Content-Security-Policy.	نهایی محصول.
SEC-04	RateLimitConfig.java	۱ .خواندن صرفاً X-Forwarded-For قابل جعل.( ) ۲ .محدودیت ۶۰ درخواست در دقیقه روی تمامی مسیرها از جمله /sitemap.xml و /seo/.	ربات گوگل یا تلگرام هنگام ایندکس کردن سریع لینک‌ها با خطای 429 Too Many Requests مسدود می‌شد.	۱ .اولویت دادن به هدر غیرقابل جعل X-Real-IP تنظیم‌شده توسط Nginx. ۲ .معاف کردن مسیرهای /sitemap.xml و /api/articles/seo/ از Rate-Limit. ۳ .افزایش سقف به ۱۲۰ درخواست در دقیقه.	جلوگیری از مسدود شدن خزنده‌های موتورهای جستجو و جلوگیری از برخورد کاربران واقعی به خطای 429.
SEC-05	GlobalExceptionHandler.java.java	برگرداندن کد 400 BAD_REQUEST برای تمامی RuntimeExceptionها (حتی زمانی که خبر پیدا نمی‌شد).	وقتی خبری وجود نداشت، به جای کد استاندارد 404، کد 400برگردانده می‌شد که برای ربات‌های سئو و کلاینت گمراه‌کننده بود.	بررسی پیام خطا و برگرداندن HttpStatus.NOT_FOUND (404) در صورت عدم وجود خبر یا کلستر.	رعایت استاندارد های معماری REST و ارسال سیگنال صحیح HTTP به موتورهای جستجو.